

FR-20: Đăng nhập trên Mobile (Mobile Login)

- **Module:** MOBILE_LOGIN
- **Requirement ID:** FR-20

Nguồn tham chiếu: README chỉ nêu FR-20 (Tính năng Mobile) ở mức "phải có đầy đủ chức năng Đăng nhập" và dùng chung backend API với Web. Các quy tắc chi tiết của chức năng Đăng nhập (bộ đếm sai, khóa tài khoản, JWT...) được kế thừa từ FR-02, vì Mobile và Web gọi cùng một API backend nên phải tuân theo cùng logic nghiệp vụ.

Input Fields

Field	Data Type	Constraints	Notes
Email	String (email format)	Bắt buộc; phải đúng định dạng email hợp lệ	FR-22 yêu cầu trường email dùng <code>type="email"</code> trên Web; trên Mobile không có thuộc tính HTML5 này nên cần validate đúng định dạng email tương đương bằng logic ứng dụng
Mật khẩu (Password)	String	Bắt buộc	Trường phải ẩn ký tự nhập trên Mobile (tương đương <code>type="password"</code> trên Web — theo FR-22)

Business Rules

- Mobile phải có đầy đủ chức năng Đăng nhập như trên Web và dùng chung backend API (theo FR-20).
- Sau mỗi lần đăng nhập sai, hệ thống tăng bộ đếm đăng nhập sai lên đúng 1 đơn vị (kế thừa từ FR-02).
- Nếu đăng nhập sai từ 3 lần liên tiếp trở lên, tài khoản bị tạm khóa 30 giây (môi trường demo); hệ thống trả về thông báo lỗi phù hợp, không để lộ chi tiết nguyên nhân (sai email hay sai mật khẩu).
- Đăng nhập thành công trả về JWT Token; token phải được lưu trữ phía client (Mobile) và gửi kèm tất cả các request có xác thực qua header `Authorization: Bearer <token>`.
- Bộ đếm đăng nhập sai và trạng thái khóa được quản lý tại backend, dùng chung cho mọi client — hành vi khóa tài khoản giống nhau dù đăng nhập từ Web hay Mobile.

Expected Outcomes

- *Success:* Email và Mật khẩu hợp lệ, khớp với tài khoản đã đăng ký, tài khoản không bị khóa → đăng nhập thành công, nhận JWT Token, chuyển vào màn hình chính của app.
- *Failure:*
 - Bỏ trống Email hoặc Mật khẩu → lỗi "trường bắt buộc".
 - Email sai định dạng → lỗi định dạng email.
 - Email hoặc mật khẩu không đúng → lỗi đăng nhập (không nêu rõ trường nào sai), bộ đếm sai tăng thêm 1.
 - Đăng nhập sai từ lần thứ 3 liên tiếp → tài khoản bị tạm khóa 30 giây, hệ thống trả về thông báo lỗi phù hợp (không lộ nguyên nhân khóa).
 - Đăng nhập trong lúc tài khoản đang bị khóa → bị từ chối dù nhập đúng Email/Mật khẩu, kèm thông báo lỗi phù hợp.